Assessment 01: Security foundations

Task A

Risk	Asset	CIA Impact	Control	Limitation
Weak, Reused Passwords	Email and Learning Portal accounts	Compromises **Confidentiality** (attackers can read private emails) and **Integrity** (attackers can alter portal submissions).	Use a password manager to generate and store unique, complex passwords for every site.	Password Manager becomes an SPOF; if it is breached, all accounts are compromised
Blindly Approving MFA Prompts	All accounts protected by this MFA	Compromises **Confidentiality** and **Integrity** because approving an unexpected prompt grants an attacker who already has her password full access to her accounts.	Strictly deny any prompt she didn't initiate.	Denying prompts relies entirely on continuous user vigilance.
Postponing Device Updates	Laptop operating system and local data.	Compromises **Availability** and **Confidentiality**, as unpatched vulnerabilities can be exploited by malware or ransomware to lock her out of her device or steal data.	Enable automatic software and OS updates to install during inactive hours.	Automatic updates can occasionally introduce bugs or compatibility issues with existing software.
Single Local Copy of Project	Project files.	Compromises **Availability**. If the laptop is lost, stolen, or experiences hardware failure, the project is permanently destroyed.	Set up automatic cloud syncing (e.g., Google Drive, OneDrive) for her project folder.	Cloud backups require a reliable internet connection to remain current.
Sharing an Active User Profile	Local files and active browser sessions.	Compromises **Confidentiality** (the friend can inadvertently view private emails or files) and **Integrity** (the friend might accidentally delete or modify the project file).	Create a standard, non-administrator "Guest" user account on the laptop for her friend.	Requires disk space for a second profile and the friend cannot install their own software.

Priority Actions:

1. **Stop approving unexpected MFA prompts and change passwords.** (Someone already has her credentials if she is receiving unexpected prompts; this is an active breach).
2. **Back up the project to the cloud.** (Ensures her most critical asset is immediately safe from imminent ransomware or hardware failure).
3. **Enable automatic updates.** (Closes the software vulnerabilities that automated malware exploits).

Authentication vs. Authorisation

Authentication is the process of verifying Mira's identity. When Mira goes to her learning portal and enters her username, password, and approves a legitimate MFA prompt, the system is authenticating that she is genuinely Mira.
Authorisation is determining what Mira is allowed to do once she is logged in. After the portal authenticates her, its authorisation rules allow her to view her own courses and submit her assignments, but restrict her from viewing other students' grades or deleting the course syllabus.

Task B

Warning Signs Analysis

Evidence Quote	Scrutiny Explanation
"Reply-To: help@personal-awards.example"	The reply domain mismatches the official campus.example domain, indicating an external, unverified sender bypassing institutional channels.
"expires in 20 minutes"	Creates severe artificial urgency to trigger panic, bypassing the recipient's logical scrutiny and forcing immediate action.
"enter your college password and OTP"	Solicits highly sensitive authentication credentials via an unsolicited, external link—a classic credential harvesting technique.
"Do not contact the college office"	Deliberately isolates the target, attempting to cut off official support channels and prevent independent verification of the narrative.
"Reply with a photo of your identity card"	Unnecessarily harvests personally identifiable information (PII) directly over email, which is highly indicative of identity theft preparation.

Safe Verification Process

1. Close the suspicious message without clicking any links or downloading attachments.
2. Open a new, secure browser window.
3. Manually navigate to the official college portal by typing `campus.example` directly into the address bar or using a trusted bookmark.
4. Check the official student dashboard for financial aid notifications, or contact the scholarship office using a verified phone number from the official campus directory.

Security Limitations: An HTTPS padlock only encrypts the connection between the browser and the server; malicious actors routinely register fake domains (like `campus-awards.example`) and

obtain free SSL certificates to make their phishing sites appear secure. Similarly, a display name like "Scholarship Desk" is simply unverified text chosen by the sender and offers zero proof of actual identity or affiliation.

Compromised Account Response Plan

1. **Immediate Containment:** Navigate to the official college portal directly and change the account password immediately to lock out the attacker.
2. **Session Revocation:** Use the account security settings to force a sign-out of all active sessions, invalidating the intercepted OTP.
3. **Official Reporting:** Contact the campus IT Helpdesk and campus security to report the credential compromise and the compromised ID.
4. **Follow-Up Checks:** Review the student account for unauthorized modifications, paying special attention to altered direct deposit routing numbers or hidden email forwarding rules.
5. **Identity Monitoring:** If the ID photo was sent, the student should notify the issuing office to flag the ID and monitor their credit profile for identity fraud.

Unestablished Fact

This message alone cannot establish whether this is a targeted attack (spear-phishing) leveraging stolen student rosters, or a generic mass-blast phishing campaign. Additional evidence, such as full email header analysis to trace the origin IP and campus mail server logs to see how many recipients received the exact same payload, would be required to determine the attacker's scope and prior knowledge.

Task C

Four-Point Timeline

1. **09:00 - 09:01:**
    - *Observed:* A successful password and MFA login occurred for student07 from 192.0.2.10, the usual classroom egress IP.
    - *Interpretation:* The student established a legitimate, authorized session while in the classroom, which aligns with their statement of signing in before 09:05.
2. **10:14 - 10:16:**
    - *Observed:* Two failed password attempts followed by a successful password entry from a new IP, 198.51.100.23.
    - *Interpretation:* An unauthorized actor likely guessed, brute-forced, or used compromised credentials to pass the first authentication layer, as the user stated they did not attempt to sign in during this time.
3. **10:17 - 10:18:**
    - *Observed:* An MFA prompt was denied, followed immediately by an approved MFA prompt from the new IP. The user stated they approved a prompt around 10:18 to stop repeated requests.
    - *Interpretation:* The attacker executed an MFA fatigue attack. The user, annoyed or confused by the alerts, mistakenly authorized the malicious login attempt.
4. **10:20:**
    - *Observed:* A session was successfully created for student07 from 198.51.100.23.
    - *Interpretation:* The attacker fully compromised the account and gained access to the system.

Explanations and Checks

- **Likely Explanation:** The account suffered an MFA fatigue attack. An attacker obtained the user's password, initiated authentication from 198.51.100.23, and spammed the user with MFA prompts until the user approved one out of frustration.
- **Alternative Explanation:** The student left the classroom, connected to a cellular network or VPN (resulting in the 198.51.100.23 IP), forgot their password initially (causing the failures at 10:14 and 10:15), and misclicked the first MFA prompt at 10:17. In this scenario, the user is misremembering or lying about their actions after 09:05.
- **Additional Checks:**
    1. Analyze network intelligence or VPN logs to see if 198.51.100.23 resolves to a known commercial VPN, malicious infrastructure, or a local mobile carrier.
    2. Audit the actions taken within the 10:20 session (e.g., mass file downloads, inbox rule creation) to see if the behavior matches typical student activity or malicious exfiltration.

Prioritised Response Actions

1. **Account Protection (Containment):** Immediately revoke all active authentication tokens and sessions for student07 to sever the attacker's access, and force a mandatory password reset.
2. **Preservation of Evidence:** Export and securely archive the authentication logs, MFA telemetry, and session logs for student07 and the IP 198.51.100.23 before log retention policies overwrite them.
3. **Post-Incident Investigation:** Review the system's audit logs from 10:20 onward to determine if sensitive data was accessed, if lateral movement was attempted, or if persistent backdoors (like forwarding rules) were created.

Incident Summary

On 18 October 2026, account student07 experienced a high-priority compromise. Logs indicate a successful password authentication from an unfamiliar IP (198.51.100.23) at 10:16, followed by an MFA approval at 10:18. The user reported they did not initiate this login but admitted to approving a prompt to stop repeated alerts. This evidence strongly indicates a successful MFA fatigue attack. It remains uncertain if malicious actions were performed after the session creation at 10:20. The immediate next action is to revoke active sessions, reset the compromised password, and investigate post-login activity.

Task D

Five Unsafe or Unsupported Claims and Corrections

- **Claim 1: "The email is safe because it uses HTTPS."**
  - **Correction:** HTTPS only encrypts the traffic in transit between the client and server; it does not validate that the site's content is legitimate. Threat actors routinely use free SSL/TLS certificates to host phishing pages securely.
- **Claim 2: "The sign-in logs prove that the person using 198.51.100.23 stole the password."**
  - **Correction:** Logs only provide evidence of authentication from a specific IP address. It is an assumption to state they "stole" it, as the credentials could have been purchased from a broker, reused from a different breach, or the IP could be a proxy or VPN.
- **Claim 3: "MFA prevents every account compromise."**
  - **Correction:** Standard MFA is not foolproof. Attackers can bypass it using Adversary-in-the-Middle (AiTM) proxy setups to steal session cookies, SIM swapping, or MFA fatigue.
- **Claim 4: "Delete the suspicious logs..."**
  - **Correction:** Deleting logs violates incident response and digital forensics protocols. Logs must be preserved for chain of custody, threat hunting, and determining the blast radius of an incident.
- **Claim 5: "...and send the student's password to support so they can test it."**
  - **Correction:** Passwords must never be transmitted in plain text, shared, or requested by support staff. Standard security protocols require treating current passwords as highly sensitive secrets and relying on secure, user-initiated password resets instead.

Improved AI Prompt

"Act as a security analyst reviewing the provided synthetic email headers and sign-in logs. Do not use, request, or output any real student data, personally identifiable information, or plaintext passwords. Analyze the provided data to separate established facts (what the logs explicitly show) from assumptions (actor identity or intent). Clearly state your level of uncertainty for any conclusions drawn. Summarize the potential risks without recommending destructive actions like log deletion."

Corrected Security Advice

The phishing email poses a high risk despite using HTTPS, as encrypted connections do not guarantee a destination is benign. The sign-in logs indicate an anomalous authentication event from IP 198.51.100.23 using the student's credentials, which confirms an unauthorized login, though the exact method of credential acquisition remains unconfirmed. While MFA was active, it may have been bypassed via an adversary-in-the-middle attack or session hijacking.

System administrators must immediately isolate and preserve all related system logs for forensic investigation rather than deleting them. IT support must not request or handle the student's current password under any circumstances. Instead, responders should force a global session revocation for the affected account and guide the student through a secure, self-service password reset and MFA device verification process.

AI-Use Declaration and Evidence Notes

- **Declaration:** AI not used
- **Reference Note 1:** CompTIA Security+ SY0-701 Incident Response frameworks strictly mandate the preservation of logs for chain of custody and prohibit destructive actions during the containment phase.
- **Reference Note 2:** CISA guidelines on Phishing-Resistant MFA detail how standard implementations (like SMS or push notifications) are vulnerable to interception and do not guarantee complete protection against compromise.